

Tool: Backend Implementation Self-QC Checklist

Apa: daftar periksa mandiri sebelum handoff BE — gabungan dimensi ISO 25010 + mandate Tata (F-1, Data SACRED, no silent auto). **Kapan dipake:** tiap selesai impl, **sebelum lapor "beres"** & sebelum review @kakashi (SOP-SA-02, Data SACRED items dari SOP-SA-04). **Framework:** ISO/IEC 25010 (quality), Tata mandate, OWASP. **Aturan:** semua  + **ada evidence** (curl/Postman + test pass) → handoff. Ada  → fix dulu, **gak ada "should work"**.

Functional

- [] **Happy path** — works end-to-end (evidence: curl output)
- [] **Edge cases** — empty / max / special char / unicode
- [] **Error paths** — proper status + error code (dari error-code-table)
- [] **Idempotency** — mutation sensitif retry-safe (kontrol SA-C6)

Data integrity (Data SACRED — Tata mandate)

- [] **NO hard delete** — pakai `deleted_at` (soft delete) — `DELETE FROM` = 0 (SA-C4)
- [] **NO overwrite tanpa jejak** — data sensitif (money/saldo) append/merge/event-log
- [] **Audit trail** — siapa-kapan-ngapain di-log (kolom audit / event)
- [] **Auto-action eksplisit** — auto-settle/dedup di-log + notif user, **gak silent** (SA-C5)
- [] **Transaction boundary** — multi-statement dibungkus, no partial commit
- [] **Optimistic locking** — concurrent edit pakai `version` (anti lost-update)

Security (OWASP)

- [] **Input validation** — schema-based (Zod/joi/ajv) di boundary
- [] **SQL parameterized** — never string-concat (SA-C2)
- [] **Auth enforced** — route protected, role/owner checked (SOP-SA-03)
- [] **Rate limit** — endpoint sensitif (login/signup/payment)
- [] **Secret not committed** — env var (12-Factor), `.gitignore`
- [] **Error gak leak** — no stack/secret ke client

Observability (SOP-SA-05)

- [] **Structured log** — JSON, req-id + user-id + action + outcome
- [] **No console.log** di prod

- [] **Health check** `/health`
- [] **RED metric** — rate / errors / duration (koord @levi)

Performance

- [] **N+1 absent** — confirmed
- [] **Query EXPLAIN** — joint @shikamaru kalau heavy
- [] **Index in place** — confirmed @shikamaru

Sustain (Tata mandate — bukan first-aid)

- [] **Clean separation** — handler → service → repository
- [] **Naming descriptive** — `processOrderPayment`, bukan `doStuff`
- [] **No tambal-sulam** — fix root, bukan add flag/exception band-aid
- [] **Stack-lock** — prototype pakai Fauxbase, bukan Express/mock manual

Testing

- [] **Unit** — service logic covered
- [] **Integration** — endpoint level
- [] **Test passes locally** (evidence attached)

Documentation

- [] **API contract** — OpenAPI-style, di-lock @killua
- [] **Error code table** — sinkron
- [] **Example request/response** — di doc

CONTOH TERISI

Self-QC: `POST /api/orders/{id}/payments` (Proyek-Contoh, 2026-05-29)

- ✓ Happy path: curl → 201 + payment_id (output di log)
- ✓ Edge: amount=0 → 400 VALIDATION_ERROR; amount=20jt → 422 PAYMENT_LIMIT_EXCEEDED
- ✓ Idempotency: replay Idempotency-Key sama → 409 PAYMENT_ALREADY_PROCESSED (record lama, gak double)
- ✓ Data SACRED: status uang via event log append-only — no overwrite. deleted_at ada. DELETE FROM :table
- ✓ Auto-settle: webhook → log `payment.settled` + notif merchant (gak silent)
- ✓ Auth: tanpa token → 401; user belum verif → 403; akses order orang lain → 403 NOT_ORDER_OWNER
- ✓ Rate limit 10/min/user; input Zod; query parameterized
- ✓ Log JSON req-id+user-id; no console.log; /health up
- ✓ Joint @shikamaru: index (invitation_id, created_at); no N+1 (event di-batch)

✓ Unit (service) + integration (handler) pass
→ Handoff @l (integration test) + @killua (consume). Lapor @kakashi review.

Tercatat di `log.md` + jadi evidence audit (kontrol SA-C4/SA-C5/SA-C6). **Evidence-first: curl output + test pass dilampirkan, bukan "should work".**